

Threat Actor Focus

In 2025, cybercriminal success was defined by speed—and breakout time is the clearest measure of how little time defenders have. Attackers averaged a 34-minute breakout time, and, in the fastest case, reached lateral movement in just 4 minutes (an 85% acceleration over the 27-minute record in 2024), leaving little margin for manual response.



34m

average breakout time



4m

fastest breakout time



85%

acceleration over previous record

This section explains how adversaries sustained that pace by securing high privileges up front through reconnaissance and social engineering, and why stopping an intrusion pre-breakout is often the difference between a contained event and a cascading enterprise incident.

We also cover the broader shift in threat behavior: a more volatile ransomware ecosystem (affiliate churn and rapid data theft over encryption) alongside nation-state operations that trade speed for persistence and even move on year-long timelines.

Together, these realities frame the challenge for security leaders: Defend against both the 4-minute breakout and the multi-year foothold by tightening pre-breakout controls, improving cross-environment visibility, and accelerating detection and response.

How Cybercriminals Broke Out and Cashed In in 2025

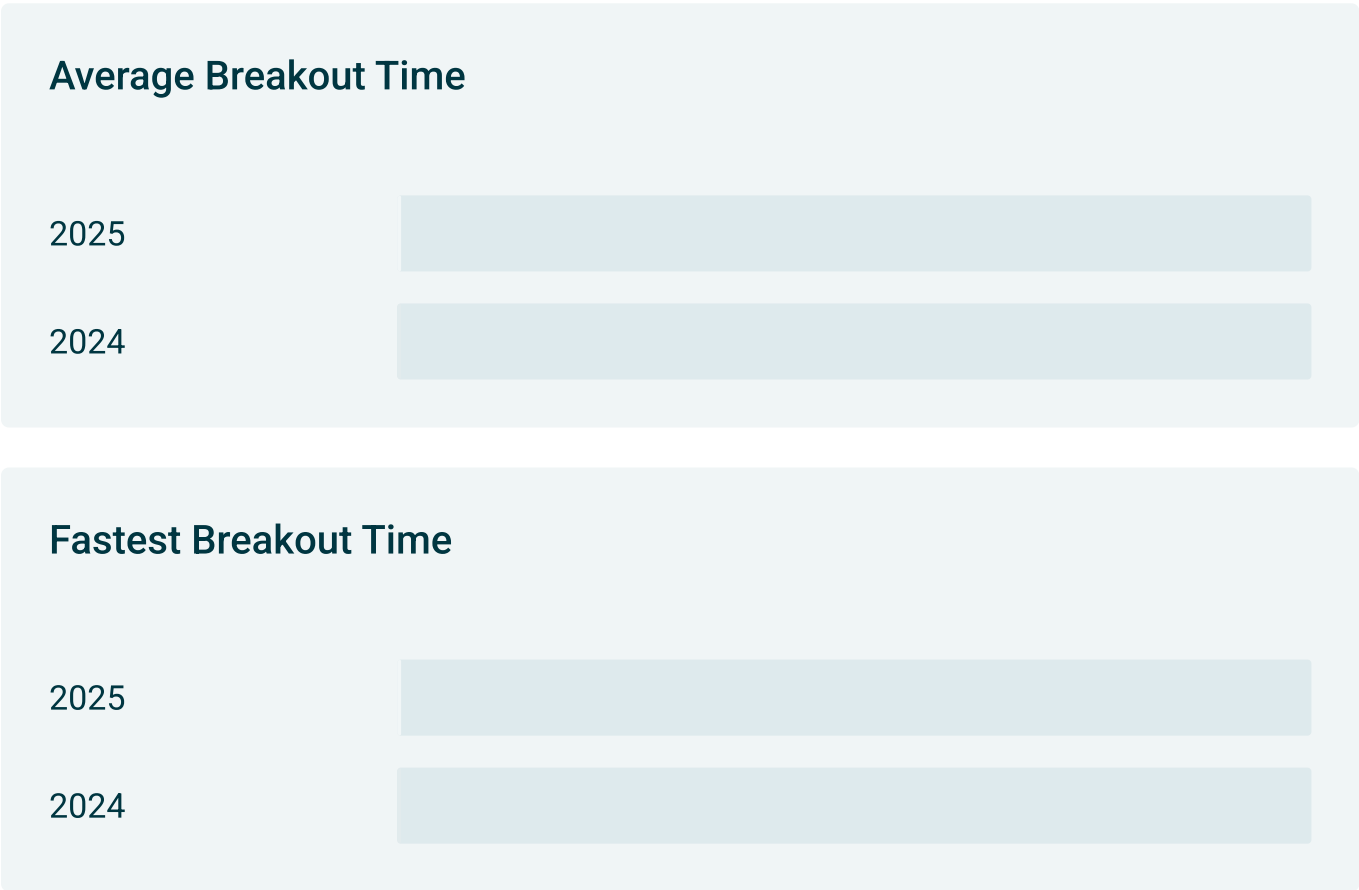
Shrinking breakout times reflect how well adversaries have optimized their attack sequences. Average breakout times declined by nearly 30% year-over-year, but the fastest threat actors drove down their timelines by a stunning 85%, dropping from 27 minutes to just 4.

The actions behind these breakout speeds take place well before intrusion. Adversaries are investing more in reconnaissance and pre-positioning more than ever

before, leaving defenders with little margin for error.

This section breaks down what drove this year’s rapid breakout time, why it’s so much harder to defend post-breakout, and which controls reduce that risk. We also take a closer look at ransomware trends over the year, including affiliate rotation and the shift to extortion-only campaigns.

Reconnaissance Fuels 4-Minute Breakout



While average breakout time continued to shrink, the most alarming change was how far the fastest breakout times collapsed. Breakout time is the critical window between initial access into a system and lateral movement to another asset. It’s one of the most important metrics for defenders because it defines the opportunity to detect and contain an intrusion before it spreads. Once an attacker gets in—whether

through phished credentials, an exploited vulnerability, or a compromised third party—the clock starts.

Measure Twice, Cut Once: Attackers' Careful Preparation

To ensure the fastest possible breakout, attackers invest significant effort in reconnaissance and preparation, using open-source intelligence (OSINT) to identify and profile high-value users within target organizations and pre-build believable social engineering.

The Art of Pre-Intrusion Reconnaissance

Before an attack, threat actors are preparing by:



Identifying high-privilege users.



Mapping organizational structure.



Finding environment information.



Gathering personal information.
Understanding internal processes.

We expect attackers to increasingly [leverage AI to accelerate this reconnaissance phase](#), automating analysis of social media profiles, corporate websites, and other public data sources to craft convincing social engineering scripts, and compress days of manual research into hours or minutes. Without proactive defense, by the time initial access has occurred, attackers already know who to call, what to say, and where to move.

The fastest breakout times we observed happened when social engineering was used for initial access. Groups like Scattered Spider show how extensive reconnaissance directly enables sub-5-minute lateral movement. They identify high-value targets in advance and use the collected personal details to secure privileged access, making “privilege escalation” effectively unnecessary.

The difference in defending an attack before and after breakout is stark. Pre-breakout, defenders are dealing with one compromised system, limited data exposure, and straightforward remediation. Post-breakout, they’re suddenly managing multiple compromised systems, higher odds of attackers gaining domain-wide access, heavier forensic investigations, and significantly higher risk of data exfiltration or encryption. Each additional system an attacker reaches multiplies scope, cost, and complexity.

Organizations have begun to adopt tactics like automated incident response to combat increasingly fast breakout times. GreyMatter customers using Automated Response Playbooks achieved an average containment time of 4 minutes—keeping pace with the fastest breakouts. Without automation, average containment stretched to 16 hours, leaving defenders behind in a race they can’t win.



0 minutes

Average containment
time with automation



0 hours

Average manual
containment time



Take Action Against Fast Breakout Time

- Require multifactor identity verification for password resets, MFA changes, or account modifications. Use out-of-band callbacks to pre-registered numbers and secondary authentication challenges that can't be satisfied through publicly available information.
- Use digital risk protection tools to continuously monitor social media, public databases, and the dark web for exposed employee information and organizational intelligence that attackers use during reconnaissance.
- Implement network segmentation, restrict administrative access to jump servers or PAM solutions, and ensure service accounts have minimal permissions to restrict lateral movement.

Ransomware Fractures into a Swarm of Smaller, More Agile Groups

The era of ransomware “giants” is fading. In 2025, we watched as the landscape fragmented into a swarm of smaller, agile groups following law enforcement disruptions. We saw a record total of 84 data-leak sites active in Q3, as affiliates moved freely between programs, keeping a wider variety of RaaS operations viable and active simultaneously. With fewer dominant players setting the norm, the cross-pollination of tactics has increased, targeting is less predictable, and attacks are harder to anticipate.

Fragmentation also drove volume. In 2025, 7,734 organizations were named on ransomware data-leak sites, a 47% increase over 2024. Unless a dominant player emerges to centralize these affiliates, we expect this “swarm” dynamic to continue and drive attack volume even higher as new groups launch unique operations.


0

organizations were named on ransomware data-leak sites


0%

increase over 2024

Count of Organizations Named on Data-Leak Sites, by Group

	2025	2024
Qilin	1009	175
Akira	622	234
Clop	509	26
Play	382	342
Safepay	365	45
Inc Ransom	364	166
Lynx	259	75
RansomHub	240	534
Sinobi	172	0
Medusa	160	211
DragonForce	143	90

Mass Exploitation Defines the Market Leaders

The most successful ransomware groups of 2025 consistently relied on mass vulnerability exploitation for initial access, often paired with automation.

The “Clop” ransomware group best exemplifies this strategy. Known for operating in bursts, the group has repeatedly exploited vulnerabilities in managed file transfer (MFT) systems and struck at scale. Its February MFT campaign fueled a 23% spike in overall ransomware activity in Q1 alone.

In October, Clop pivoted to a different software target. We observed victims receiving extortion emails claiming data theft sent from compromised legitimate accounts within their own organization, helping the group bypass email filters.

While Clop moved in waves, “Qilin” maintained a steady offensive. It was the most active ransomware group in 2025, claiming 387 more victims than its closest competitor, Akira. It listed 188 organizations on its data-leak site in October alone.

Qilin’s dominance can be explained by its business-like operations and aggressive recruitment. Beyond exploiting vulnerabilities (including CVE-2024-55591 and CVE-2024-21762), Qilin also partnered with initial access brokers (IABs) to obtain VPN access, enabling faster, coordinated attacks that bypassed EDRs and avoided noisy exploitation.

Attackers Are Hunting Your Tech Stack

In 2025, ransomware groups focused less on targeting sectors and more on targeting the software platforms that serve them. Attackers increasingly moved upstream, hitting technologies with the potential to unlock entire industries at once.

Count of Organizations Named on Data-Leak Sites, by Sector

	2025	2024
Professional, scientific, and technical services	1984	1079
Manufacturing	1383	1098
Construction	725	524
Health care and social assistance	644	500
Retail trade	519	396
Finance & insurance	439	347
Educational services	321	246
Accommodation and food services	276	195
Arts, entertainment, and recreation	271	149
Public administration	250	241
Information	219	177
Real estate and rental and leasing	213	107
Wholesale trade	158	69
Mining, quarrying, and oil and gas extraction	153	118
Utilities	136	64

For example, one Clop campaign set Cleo’s MFT solution in its sights. Thanks to Cleo’s popularity with retailers for managing e-commerce transactions and fulfilling orders, the Clop campaign drove a 153% increase in retail-trade targeting between Q4 2024 and Q1 2025.



We also saw an 84% increase year-over-year in ransomware activity affecting the professional, scientific, and technical services (PSTS) sector. Qilin’s penchant for targeting this sector (accounting for 17% of all organizations named on its data-leak sites) and Akira’s recent SonicWall campaign likely contributed to this spike, as most SonicWall customers are IT services and consulting firms. In the SonicWall campaign, Akira weaponized a single firewall vulnerability to destabilize the companies responsible for securing others.

Geographically, the US remained the primary target due to its revenue potential—but a shift is underway. Countries with rapidly growing digital economies, where infrastructure growth often outpaces cybersecurity maturity, are facing disproportionate targeting. Attackers are aggressively exploiting the gap between fast-expanding digital infrastructure and lagging cybersecurity maturity in these regions.

Count of Organizations Named on Data-Leak Sites, by Region

	2025	2024
US	4223	2760
Canada	363	296
Germany	309	158
UK	270	252
France	178	121
Italy	166	137
Spain	147	107
Brazil	146	121
India	118	114

Based on these trends, we predict 2026 to bring less broad, vertical-based targeting (e.g., health care) and more technology-based targeting (e.g., users of Software X). This shift will mean third-party risk management (TPRM) will be as important as defending your own network for the coming year.

Groups to Watch: The War for Platform Dominance

The RaaS market has become a battle of technology, and automation is almost certainly speeding up ransomware attacks, with 80% of the RaaS groups we analyzed now offering some form of automation or AI features. Platforms built on [automation, customization, and advanced tool sets likely attract the most skilled affiliates](#) who can use them to compromise higher-revenue organizations and increase the odds of a successful extortion payment.



Percentage of analyzed RaaS groups offering automation or AI platform features

Despite being the most active ransomware group in 2024, “LockBit” struggled to recover after law enforcement disruption. The group listed 70% fewer organizations on its data-leak site in 2025. But a weakened player can still be dangerous. In June 2025, LockBit announced “LockBit 5.0,” a platform overhaul designed to win back affiliates. Early efforts to regain dominance fell short, but in December the group resurfaced with a surge in named organizations.

As LockBit stumbled, groups like “The Gentlemen” and “DragonForce” moved to fill the gap by offering more feature-rich platforms with advanced capabilities similar to Qilin. Over the next 12 months, these groups are well positioned to become significant threats.

We expect emerging cybercriminal groups to embrace louder branding campaigns in 2026 to attract affiliates, while more established actors prioritize operational secrecy to avoid law enforcement scrutiny. These contrasting tactics will create prioritization challenges for security teams, potentially leading to operational overload and exposing organizations to stealthier, more dangerous threats



Take Action Against the Rise of Ransomware and Automated Extortion

- Disrupt automated attacks by maintaining a zero-tolerance policy for patching delays on external-facing assets.
- Shift risk modeling from industry verticals to technology dependencies. Attackers select targets based on their tech stack, so defenders must maintain a real-time inventory of software exposure.

- Focus on behavioral detection over attribution to prepare for volume and unpredictability. With affiliates breaking out into different programs and sharing tradecraft, static indicators are becoming less reliable.

Your Strategy for Combatting Cybercriminal Activity

Stopping an attacker at initial access makes the difference between straightforward remediation and full-blown compromise. To defend against today's compressed timelines, organizations need proactive intelligence that identifies exposed information before attackers can use it and agentic AI to autonomously hunt, detect, and analyze threats at the speed required to contain them.

Stop Reconnaissance Before Breakout by Monitoring Your External Attack Surface

Groups like Scattered Spider show how extensive pre-attack reconnaissance—identifying IT administrators, gathering personal details, and mapping organizational structure—enables sub-5-minute lateral movement by targeting high-privilege accounts from the start. Tools like **GreyMatter Digital Risk Protection** give defenders the advantage by continuously monitoring the open, deep, and dark web for the information and infrastructure attackers use during reconnaissance so it can be addressed before an intrusion begins.

- ✔ **Monitor exposed employee and organizational information:**
Continuously scan social media, public databases, and the dark web for the exposed employee details and organizational intelligence attackers

use to craft convincing social engineering scripts and identify high-privilege targets.

- ✔ **Detect and disrupt brand impersonation infrastructure:** Identify spoofed domains, fraudulent sites, and credential leaks tied to your brand in real time. Trigger automated takedown actions to remove attacker infrastructure used for phishing and initial access attempts. Detect and disrupt brand impersonation infrastructure: Identify spoofed domains, fraudulent sites, and credential leaks tied to your brand in real time. Trigger automated takedown actions to remove attacker infrastructure used for phishing and initial access attempts.
- ✔ **Correlate external threats with internal context:** Enrich external digital risks with information about your assets, telemetry, and business priority data to prioritize exposures most likely to impact your environment.

Amplify Threat Detection and Response with Agentic AI

When SOC's are up against 4-minute breakouts, CISOs have to figure out how to scale detection, hunting, and analysis without adding headcount, complexity, or tool sprawl.

GreyMatter Agentic Teammates autonomously handle threat intelligence analysis, detection engineering, and threat hunting. These persona-based AI systems work together to create and test detections, execute hunts, analyze intelligence, and validate coverage in seconds, while retaining environment-specific context and operating with governance and transparency.



- ✓ **Turn threat intelligence into action:** Generate real-time threat reports from external sources mapped to your environment, automatically flag campaigns targeting your industry or tech stack before they strike, and connect attacker behaviors to investigations so your team can act immediately.
- ✓ **Build and validate detection coverage continuously:** Create, monitor, and validate detection rules based on emerging threat intelligence and recent incidents, simulate coverage to surface blind spots, and deploy rules across your security stack to catch lateral movement indicators early.
- ✓ **Execute continuous cross-telemetry hunting:** Run hunts aligned to attacker tactics (like credential theft or privilege escalation) across all telemetry, identify detection gaps based on real-time behavior, and correlate signals across tools that isolated detections miss.

Slow Burn Nation-State Operations Hide in Plain Sight

Unlike financially motivated cybercriminals who prioritize speed, advanced persistent threat (APT) groups focus on espionage and infiltration. From China-linked groups' methodical, long-term strategies aimed at geopolitical advantage to North Korea-backed groups' schemes to generate revenue for the regime, these actors operate outside the typical "smash-and-grab" model.

In this section, we examine APT group tradecraft through 2 case studies: China-linked group "Flax Typhoon" and North Korean state-sponsored fake IT worker personas. Both demonstrate how nation-state operations use legitimate tools and identities to operate on a much longer timeline than other groups.

These adversaries mask their persistence with the noise of legitimate daily operations, a LotL technique that leaves blind spots only discoverable through behavioral analytics and cross-tool correlation.

Bogus Applicants: The State-Sponsored Insiders

This year, we investigated [North Korean state-sponsored operatives posing as skilled freelancers or contractors to infiltrate Western companies using fake identities.](#)

North Korea has allegedly run insider threat programs for years to fund its weapons programs amid US and international sanctions. What's new this year is the scale: We observed a 116% increase in fraudulent North Korean hires in 2025 compared to 2024. We reviewed thousands of insider-threat applications across our customer base and identified more than 7,000 email addresses belonging to suspicious candidates.



Across incidents, 3 patterns showed up repeatedly:

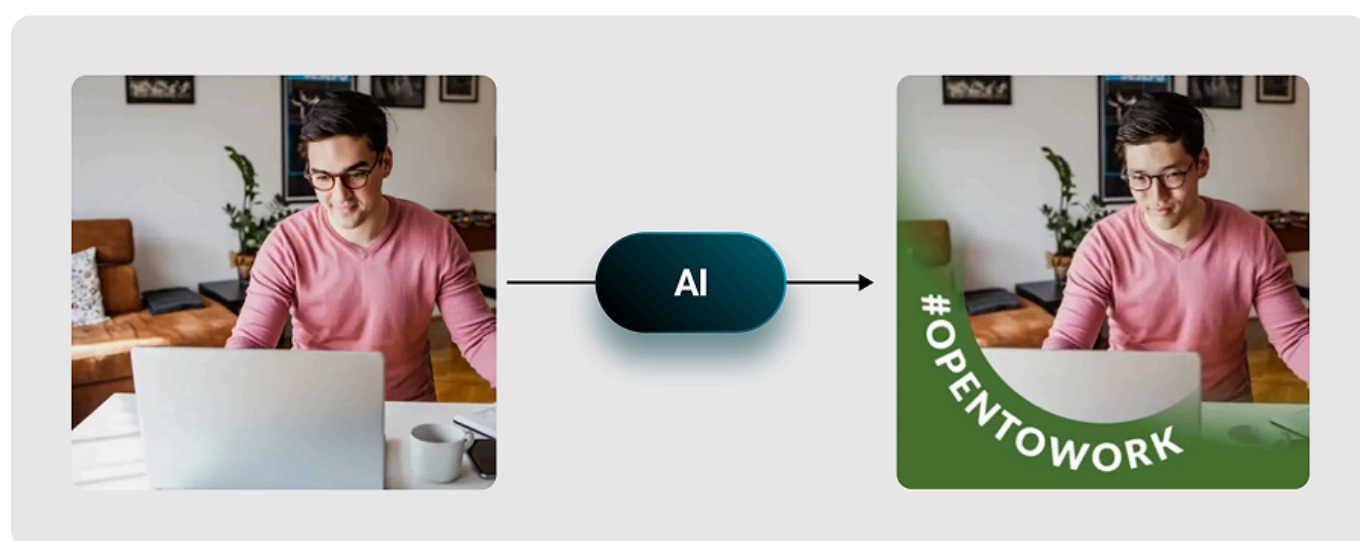
- **Targeted roles:** Operatives most often pursued freelancer and contractor positions.
- **Operational security and slip-ups:** They routinely used proxy tooling to mask location, but mistakes occasionally exposed their true origin.
- **Stealthy remote access:** They abused keyboard/video/mouse-over-IP (IP-KVM) devices to maintain control and evade scrutiny, especially in environments with corporate-owned, business-only access policies.

A North Korean insider may seem far-fetched, but it's a dominant nation-state threat. A successful hire gives a state-sponsored actor immediate access to internal networks that bypass perimeter defenses. And AI is helping these personas look more credible at scale.

Targeting Recruiters with AI-Generated Profiles and Deepfake Interviews

It starts with the hiring process. To get past recruiter screening, operatives build networks of fake social media profiles to create a convincing backstory. These profiles, complete with legitimate-looking work histories and communications, are almost entirely AI-generated, helping operatives overcome language barriers. But even with the AI assist, the profiles are often littered with red flags: low activity, implausible experience, and overly polished skill lists.

When applying to foreign organizations, North Korean operatives face another problem at the interview stage—they can't show up in-person. To work around it, they target remote-friendly freelancer and contractor roles, often in technology-related companies.



* Figure 8: AI generated LinkedIn Profile

When recruiters engage with these profiles, the operatives avoid face-to-face interaction for as long as possible. If an interview requires video, some operatives use deepfake technology to pass initial screenings without exposure.

Once they land the job, operatives weaponize onboarding and “IT troubleshooting” to establish persistent remote access, often by persuading hiring teams to install remote-access tools like AnyDesk.

This step is critical because it connects corporate laptops to their “laptop farms,” remote locations that house multiple devices, enabling full network access even before they’re fully onboarded. This allows the operatives to map the network and exfiltrate data even if the HR process later falls through.

A Day in the Life of a North Korean Insider

As for the operatives’ day-to-day, our data indicates a factory-like operating model where operatives trade shifts to maintain productivity. This means organizations aren’t hiring 1 freelancer, they’re effectively hiring a seat in a state-run facility where multiple operators work under a single “employee” persona to keep access and output high.

To maintain this façade, operatives use industrial-scale infrastructure like commercial VPNs (such as Astrill) to hide their true location, but their operational security isn’t perfect. When a VPN drops or they forget to activate it, the mask slips.

Our investigations revealed this slip clearly when we observed IP addresses belonging to Russian and Chinese internet service providers (ISPs) in remote management and monitoring (RMM) activity. This suggests North Korean insiders rely on RMM sessions to access devices in laptop farms and are authenticating from their own territory before routing traffic through US nodes.

In some cases, activity linked to both ISPs appeared within a short timeframe for the same user. This indicates either one worker using both ISPs or multiple attackers all sharing a single “employee” identity to pull off the deception.

Once an organization is flagged as viable (likely due to gaps in their hiring process), the regime swarms it with candidates. We found multiple insiders authenticating from the same fixed-line IP address, and in one extreme case, a single company

identified 10 separate North Korean insiders in a rolling wave of infiltration attempts over just 6 months.

We also observed VPS IP addresses tracing back to Russia and the US that weren't associated with commercial VPN providers. We found open ports on these endpoints containing AnyDesk certificates, suggesting RMM tool abuse to facilitate remote control. Attackers are moving away from easily blacklisted commercial VPNs toward custom, private infrastructure. By routing traffic through US-based VPS nodes, operatives can bypass standard geo-blocking policies and appear to be working from within the US.

For defenders, a single anomalous location or remote-access indicator may be the only visible thread that can unravel an entire network of insider threats.

Bypassing Defenses with Commercial IP-KVM Hardware

When software-based stealth isn't enough, operatives turn to hardware. IP-KVM devices are low-cost, customizable solutions that provide remote access to a computer's console (keyboard, video, mouse) over the internet.

Their superpower is that they operate externally. Because the device acts as a physical peripheral plugged into USB and HDMI ports, it bypasses standard EDR agents. To the operating system, the malicious remote control looks identical to a legitimate employee sitting at their desk, typing on a wired keyboard.

However, the invisibility isn't perfect. Even stealthy IP-KVMs leave behind artifacts, but detecting them requires granular device monitoring that many security teams don't have. This is one reason why North Korean workers prefer environments where endpoint visibility is limited, such as those with BYOD policies, where monitoring may be constrained by policy or privacy.



Take Action Against North Korean Insider Threats

- Mitigate the risk of North Korean insiders exploiting BYOD policies by enforcing a Corporate-Owned, Business Only (COBO) policy. This approach provides the visibility needed to spot and stop unauthorized users before they become a problem.
- Don't let rogue IP-KVM devices like TinyPilot and PiKVM slip through the cracks. Set up a USB allowlist and configure alerts for connection attempts from unauthorized devices to keep your endpoints secure.
- Threat actors commonly use RMM tools for unauthorized remote access. Stop them cold by blocking all RMM tools at both the application and network level, except for a single authorized solution.

Chinese APTs Play the Long Game

For most cybercriminals, success is measured by speed (i.e., how fast can we encrypt?). For Chinese state-sponsored actors, success is an exercise in patience.

This persistence focus is reflected in the timelines as attackers move slowly, blend in, and collect intelligence over time. In 2025 customer incidents, we observed China-linked activity with breakout times of 20-plus hours and year-long persistent access.

As the attackers' tactics shift, so must the defenders'. Instead of relying on rapid detection to combat these threats, analysts must lean on correlating data across technologies to surface subtle anomalies.

The Fight to Remain Inside the Network

A defining characteristic of the China-linked attacks we investigated this year is resilience. Because these actors prioritize deep persistence, a standard remediation

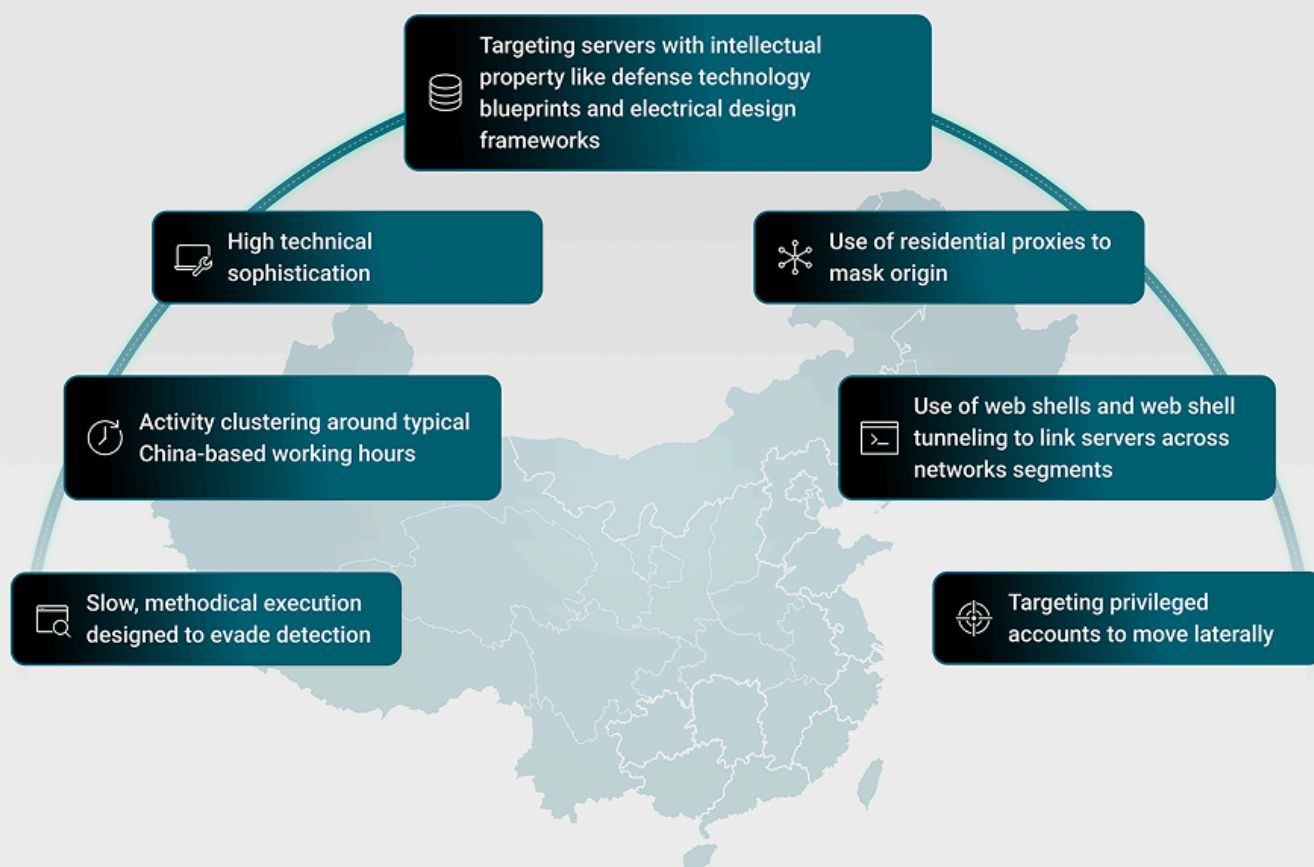
is often just a temporary disruption to their operations rather than complete removal. We've seen the full spectrum of modern espionage tradecraft and technical expertise in our incidents, including the ability to re-compromise a network after being removed.

[In one case, the adversary gained initial access by exploiting multiple SharePoint vulnerabilities before brute-forcing several service accounts.](#) Their goal was to reach a Secure File Transfer Protocol (SFTP) server holding sensitive configuration data and then disappear into normal activity. To achieve this, the adversary created files designed to impersonate legitimate files, which established a persistent backdoor that looked identical to standard business traffic.

To stay hidden, the attacker relied on sustained defense evasion. They hijacked legitimate binaries to execute malicious payloads, signing them with old but valid certificates to bypass security controls. They also ran in-memory scripts via Windows Management Instrumentation (WMI) to evade endpoint detection and wiped AD driver logs to reduce visibility into authentication activity.

Chinese Nation-State Cyber Tactics

Chinese nation-state activity looks different from the chaotic noise of a criminal gang, leaving behind a distinct footprint



The Shift from Custom Malware to LotL

For years, detecting China-linked activity meant finding custom malware families (such as the notorious “PlugX”). But in late 2025, we observed a strategic pivot away from custom tools to LotL techniques, where attackers repurposed legitimate system components instead of dropping obvious malicious files. This approach lets attackers become invisible to traditional antivirus signatures. Worse, they’re also weaponizing the organization's own disaster recovery plans against them.

In one attack we investigated, [the Chinese APT group Flax Typhoon maintained persistence for over a year](#) by modifying a Java server object extension (SOE) into a functioning web shell. Access was gated behind a hardcoded key for exclusive control, and the compromised component was embedded in system backups, so full

system recovery would restore the backdoor and enable reinfection. The attack exploited trust in legitimate software components, a common security blind spot that allowed Flax Typhoon's movements to appear as normal system operations and bypass detection tools.

The primary goal of this attack was credential harvesting. The group targeted the workstations of two IT staff and attempted to enable Remote Registry to access system configuration data, with activity consistent with efforts to dump the Security Account Manager (SAM) database, security registry keys, and Local Security Authority (LSA) secrets to obtain the credentials needed to deepen their foothold in the network.



Take Action Against Prolonged China-Linked Threats

- Inventory all internet-facing applications, even routine ones, and treat them as top-tier security priorities.
- Monitor behavioral analytics to spot anomalies in legitimate processes, like a web server component spawning unusual processes or making unexpected network connections.
- Enforce strong and unique passwords and MFA across all accounts, especially for public-facing applications. Implement the Principle of Least Privilege (PoLP) so even if an account is compromised, the attacker's access is strictly limited.

Your Strategy for Combatting Nation-State Groups

Nation-state actors succeed through persistence and stealth or by staying ahead of evolving APT persistence mechanisms. Enterprises need defense in depth that pairs behavior-based detections (to catch what signatures miss) with proactive threat hunting that surfaces persistence, credential harvesting, and anomalous privileged activity.

Detect Nation-State Persistence with Defense in Depth

Because APT tradecraft often disguises itself as normal activity, signature-based tools can miss it. To shorten time to detect, run behavioral detections across endpoint, cloud, and SaaS telemetry, and reinforce them with targeted rules that flag anomalous behavior in otherwise trusted processes.

GreyMatter customers can deploy these nation-state–focused detection rules:

- ✔ **Known DPRK Email Detected:** Flags email activity involving addresses associated with known North Korean IT worker operations, helping identify recruitment-stage infiltration attempts before access is granted.
- ✔ **Multiple Client Logins from Geographically Different Locations:** Identifies accounts logging in to corporate clients from multiple geographic locations within a short timespan, indicating impossible travel patterns. It also exposes authentication attempts from territories